

ScansioneInizio

Analisi iniziale Nessus – Metasploitable

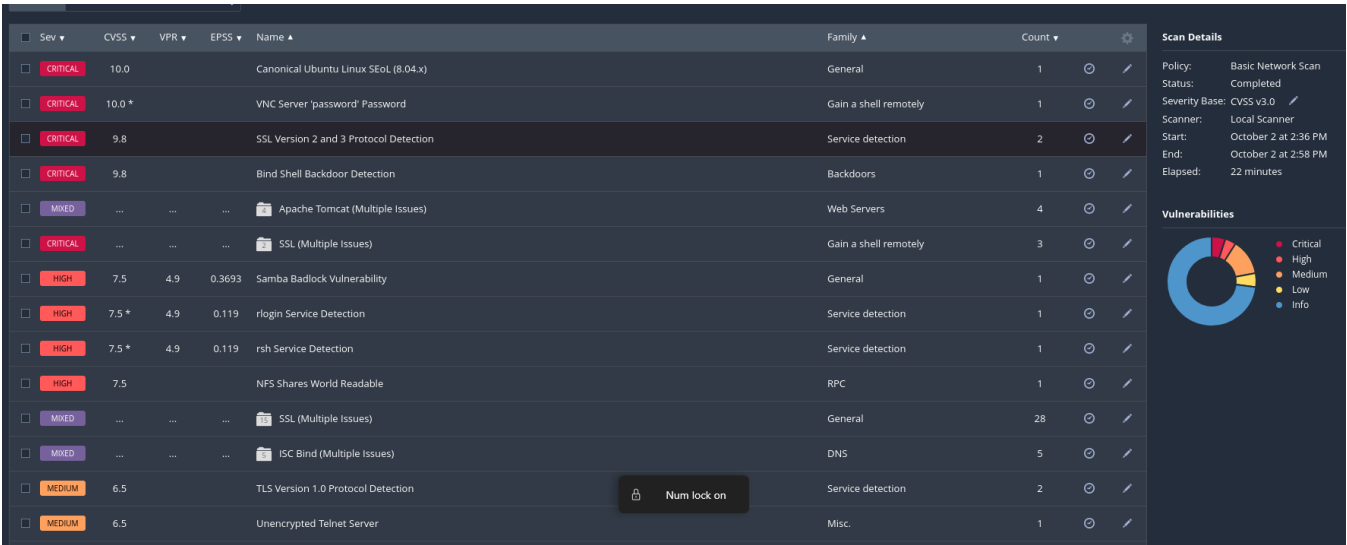
Target: 192.168.60.101 | Nessus: Basic Network Scan | Scanner: Local Scanner

Obiettivo

In questa fase è stata eseguita la scansione iniziale della macchina Metasploitable con Nessus. L'obiettivo è ottenere una fotografia della situazione di sicurezza prima di applicare qualsiasi intervento di remediation.

Risultato della scansione

La scansione è stata completata con la policy Basic Network Scan sul target 192.168.60.101. Nella vista delle vulnerabilità sono stati rilevati 70 finding. La macchina è volutamente obsoleta e vulnerabile, quindi il numero elevato di risultati è coerente con il laboratorio.



Vulnerabilità Critical individuate

Vulnerabilità	Plugin ID	CVSS	Porta / servizio	Decisione
Canonical Ubuntu Linux SEoL (8.04.x)	201352	10.0	Sistema operativo	Non modificata
VNC Server 'password'	61708	10.0	5900/tcp	Da correggere

Password				
SSL Version 2 and 3 Protocol Detection	20007	9.8	25/tcp e 5432/tcp	Da correggere
Bind Shell Backdoor Detection	51988	9.8	1524/tcp	Da correggere

Sono state quindi selezionate tre vulnerabilità per la remediation: VNC con password debole, supporto a SSLv2/SSLv3 e bind shell esposto sulla porta 1524/tcp. La vulnerabilità Ubuntu EOL è stata mantenuta come finding di riferimento, senza intervenire sul sistema operativo.

Dettaglio SSLv2 / SSLv3

Il plugin 20007 segnala che il servizio remoto accetta connessioni tramite SSL 2.0 e/o SSL 3.0. Nell'output sono inoltre presenti cipher di debolezza elevata. Nessus raccomanda di disabilitare i protocolli SSL obsoleti e utilizzare TLS 1.2 o superiore.

Hosts 1
Vulnerabilities 70
Remediations 2
Notes 2
History 3

CRITICAL
SSL Version 2 and 3 Protocol Detection

Description
The remote service accepts connections encrypted using SSL 2.0 and/or SSL 3.0. These versions of SSL are affected by several cryptographic flaws, including:

- An insecure padding scheme with CBC ciphers.

- Insecure session renegotiation and resumption schemes.

An attacker can exploit these flaws to conduct man-in-the-middle attacks or to decrypt communications between the affected service and clients.

Although SSL/TLS has a secure means for choosing the highest supported version of the protocol (so that these versions will be used only if the client or server support nothing better), many web browsers implement this in an unsafe way that allows an attacker to downgrade a connection (such as in POODLE). Therefore, it is recommended that these protocols be disabled entirely.

NIST has determined that SSL 3.0 is no longer acceptable for secure communications. As of the date of enforcement found in PCI DSS v3.1, any version of SSL will not meet the PCI SSC's definition of 'strong cryptography'.

Solution
Consult the application's documentation to disable SSL 2.0 and 3.0.
Use TLS 1.2 (with approved cipher suites) or higher instead.

See Also
<https://www.schneier.com/academic/paperfiles/paper-ssl.pdf>
<http://www.nessus.org/u7b06c7e95>
<http://www.nessus.org/u7247c4540>
<https://www.openssl.org/~bodo/ssl-poodle.pdf>
<http://www.nessus.org/u75d15ba70>

Plugin Details

Severity: Critical
ID: 20007
Version: 1.35
Type: remote
Family: Service detection
Published: October 12, 2005
Modified: April 13, 2026

Risk Information
Risk Factor: Critical
CVSS v3.0 Base Score: 9.8
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
CVSS v2.0 Base Score: 10.0
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C

Vulnerability Information
In the news: true

Dettaglio iniziale del plugin 20007: SSL Version 2 and 3 Protocol Detection.

Dettaglio Bind Shell

Il plugin 51988 rileva un bind shell sulla porta 1524/tcp. Il test di Nessus ha dimostrato che il servizio poteva eseguire il comando id con privilegi root (uid=0), rendendo il finding particolarmente grave.

Vulnerabilities
70

CRITICAL
Bind Shell Backdoor Detection

Description

A shell is listening on the remote port without any authentication being required. An attacker may use it by connecting to the remote port and sending commands directly.

Solution

Verify if the remote host has been compromised, and reinstall the system if necessary.

Output

```

Nessus was able to execute the command "id" using the
following request :

----- snip -----
This produced the following truncated output (limited to 10 lines) :
----- snip -----
root@metasploitable1/# uid=0(root) gid=0(root) groups=0(root)
root@metasploitable1/#
----- snip -----

```

To see debug logs, please visit individual host

Port
Hosts

1524 / tcp / wild_shell
192.168.60.101

Plugin Details

Severity: Critical
ID: 51988
Version: 1.10
Type: remote
Family: Backdoors
Published: February 15, 2011
Modified: April 11, 2022

Risk Information

Risk Factor: Critical
CVSS v3.0 Base Score: 9.8
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
CVSS v2.0 Base Score: 10.0
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C

Dettaglio iniziale del bind shell sulla porta 1524/tcp.

Conclusione della fase iniziale

La scansione iniziale fornisce il punto di partenza per la pratica. Le tre vulnerabilità selezionate saranno trattate nella fase di remediation e poi verificate con una nuova scansione Nessus.